

The Security Problem

Introduction

A system is secure if its resources are used and accessed as intended under all circumstances.

Security violations of the system can be categorized as intentional or accidental. It is easier to protect against accidental misuse than against malicious misuse.

A **threat** is the potential for a security violation, such as the discovery of a vulnerability, whereas an **attack** is an attempt to break security.

Security Attacks Classification

Breach of integrity - unauthorized modification of data.

Breach of availability - unauthorized destruction of data

Theft of service - unauthorized use of resources

Denial of service - preventing legitimate use of the system

Some common Security Attacks

Masquerading - one participant in a communication pretends to be someone else

A **replay attack** consists of the malicious or fraudulent repeat of a valid data transmission

Man-in-the-middle attack - in which an attacker sits in the data flow of a communication.

Privilege escalation gives attackers more privileges than they are supposed to have

System Security Measures

To protect a system, we must take security measures at four levels:

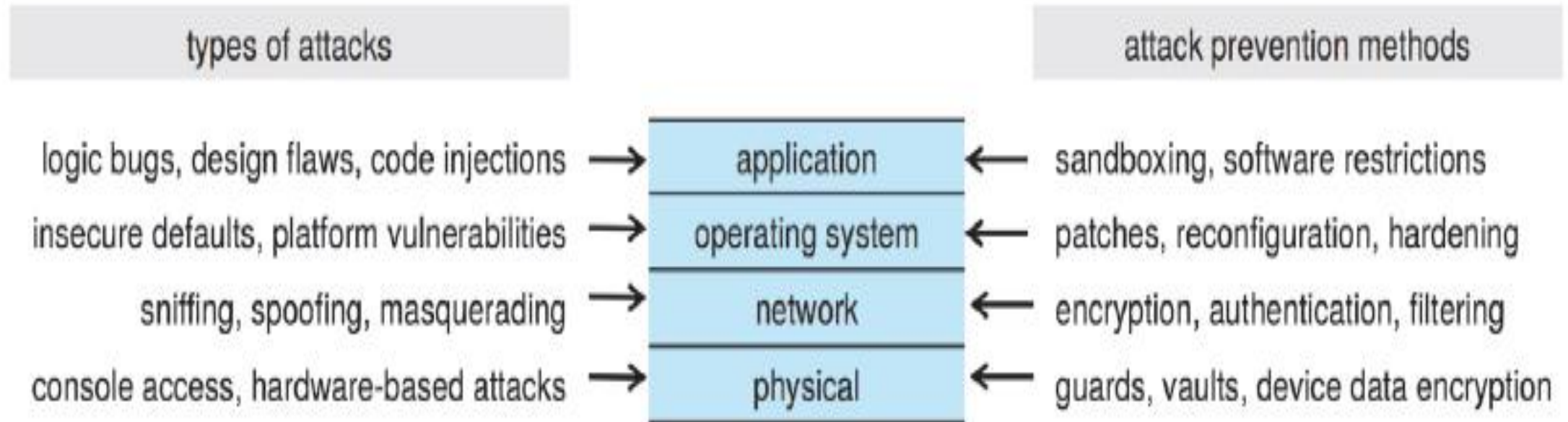
Physical- The sites containing the computer systems must be physically secured against entry by intruders

Network - provides a potential vector for unauthorized access to the system

Operating system. - Insecure default settings, misconfigurations, and security bugs are only a few potential problems

Application. Third-party applications may also pose risks, especially if they possess significant privileges

The four-layered model of security

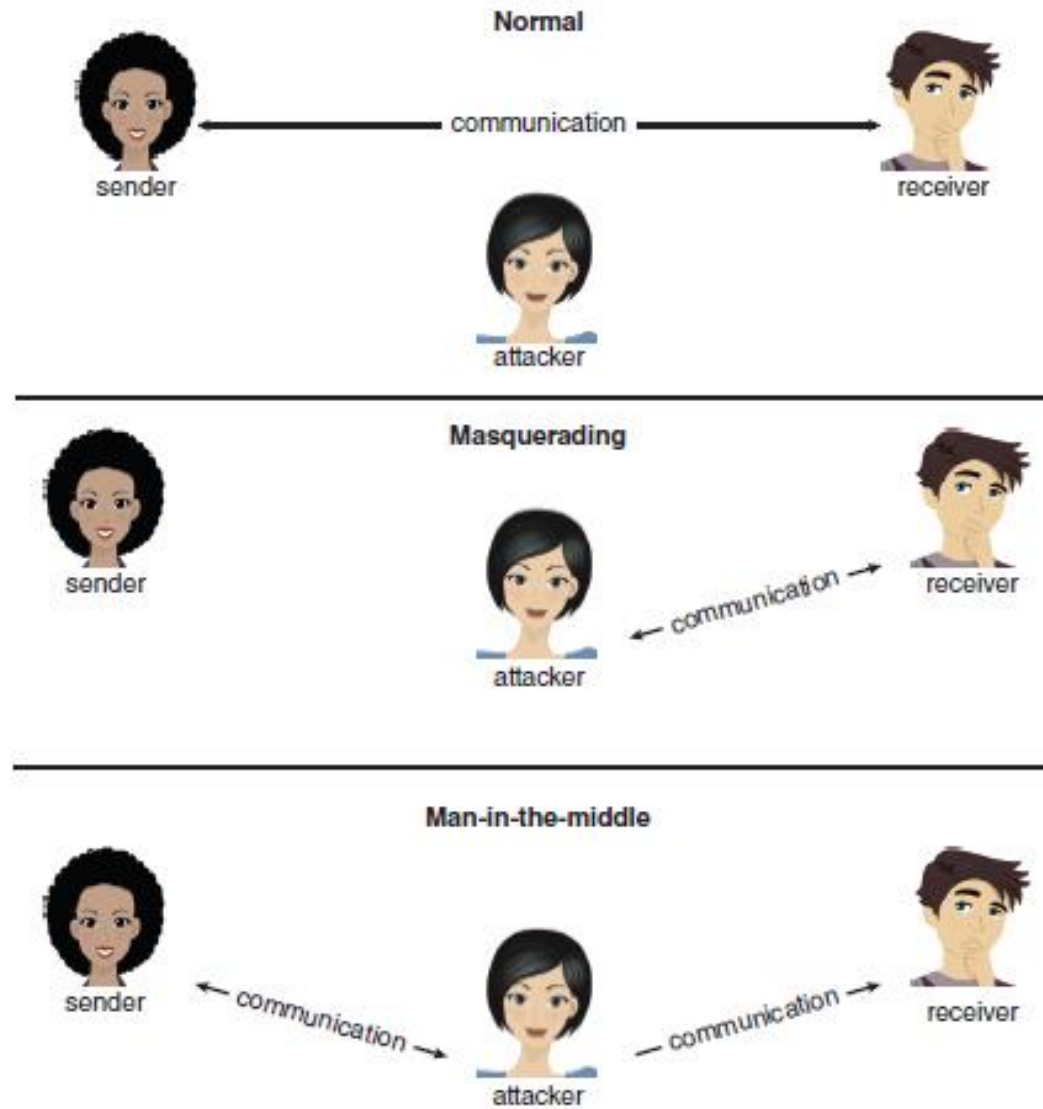


System and Network Threats

All hackers **leave tracks behind them**—whether via network traffic patterns, unusual packet types, or other means. For that reason, hackers frequently launch attacks from zombie systems.

Zombies make hackers particularly difficult to track because they mask the original source of the attack and the identity of the attacker.

System and Network Threats



Attacking Network Traffic

An attacker can opt to remain passive and intercept network traffic for obtaining useful information about the types of sessions conducted between systems or the sessions' content.

An attacker can take a more active role, either masquerading as one of the parties (referred to as **spoofing**), or becoming a fully active man-in-the-middle, intercepting and possibly modifying transactions between two peers.

Denial of Service

Denial-of-service attacks are generally network based. They fall into two categories.

Attacks in the first category use so many facility resources that, in essence, no useful work can be done.

The second category involves disrupting the network of the facility.

Port Scanning

Port scanning is not itself an attack but is a means for a hacker to detect a system's vulnerabilities to attack

Port scanning typically is automated, involving a tool that attempts to create a TCP/IP connection or send a UDP packet to a specific port or a range of ports.

An attacker attempts to deduce the type of operating system in use and its set of services in order to identify known vulnerabilities.

Many servers and clients make this easier by disclosing their exact version number as part of network protocol headers

Port Scanning

Network vulnerability scanners and nmap (a scanner) can be used

It can determine what services are running, including application names and versions.

It can identify the host operating system. It can also provide information about defenses, such as what firewalls are defending the target.